SafeFlow 安全自评报告

权限分级实现 已知风险与验证边界
2026年11月1日演示版

自评对象与安全目标

本报告说明 SafeFlow 2026年11月1日演示版的权限分级、AI 风险防护、交易安全与已知风险。结论是：系统已设置模型之外的执行约束并有相应功能验证，可用于隔离模拟业务演示；本报告属于项目自评，不是第三方渗透测试、金融合规认证或生产银行安全证明。

评估范围

范围包括 GitHub Pages 公开介绍、Netlify 银行前端、Rust API 与后台任务、PostgreSQL 业务存储、审计发送及接收流程。业务使用虚构身份和模拟资金；评委共用 user_001 演示账户。真实银行接入、真实通知渠道、生产级个人认证和可信外部存证不在本次已验证范围。

需要保护的对象

对象	保护目标
资金与卡状态	用户办理须当前有效确认和许可；管理变更另走受控入口及凭证，冻结仍在最终事务检查。
账户和交易资料	按可信会话与本人范围读取，防止跨账户或伪造标识访问。
确认与执行记录	绑定任务、操作、参数版本和期限，避免旧确认错用于新操作。
模型与数据库凭据	仅在服务端私有配置使用，不放入页面、前端包或公开下载。
审计事件和回执	持久化、去重、本地记录哈希保护和严格回执匹配；源摘要范围见审计说明。

威胁假设

不信任用户文本、浏览器存储、模型输出、前端声称的角色和外部业务文字。考虑误理解、提示注入、越权标识、重复点击、旧页面回放、网络超时、服务重启、并发写入及事件传输失败。系统不能仅依赖页面禁用按钮或提示词保证安全。

权限分级及实现

权限分级落实为会话、身份、用途、工具、操作和期限等检查，而不是由模型在回复里宣称“已获授权”。下表描述实际职责边界，不代表已经上线独立管理员控制台。

主体与能力

主体	允许能力	边界
未登录访问者	阅读介绍和使用指南	不能查询本人账单或执行银行写操作。
演示用户会话	读取本人资料，准备与确认对应业务	共用演示身份；不能自行变更账户归属或增加收款目录。
模型规划器	提出允许工具的结构化计划或澄清	无数据库、解冻、充值或任意外部调用权。
后端业务执行	在身份、安全裁决、确认和许可均有效时执行	最终事务重核来源、状态和并发条件。
独立付款后台	在已明确委托的单笔原单上继续处理	单笔30分钟及部署身份期限约束；不替用户确认。
管理与运维入口	受控演示运行、一次组织者解冻及原模拟余额凭证	无网页或模型解冻/充值入口；管理权属于受信运维边界，保留原历史。
审计发送与接收	传递及保存原事件，返回严格回执	普通用户无 raw 审计或数据库权限；回执不授予付款权。

有界确认和许可

初始确认5分钟，模拟验证最长2分钟，单次执行许可60秒；改办后草案沿既有10分钟期限，不能据此延长付款权。后台须另行明确委托，有效30分钟；登出不自动撤销，主动撤销或到期停止续办。已经受理但状态未知的原单继续核查，不能自动清占用。

归属与资源约束

后端从可信会话取得本人身份，并核资源所属及真实来源版本；客户端参数只是选择，不能授予归属。当前公开演示只配置一个可选收款人李明远（尾1024），不接受聊天新增任意真实账户。

AI 幻觉与提示注入防护

防护目标是降低错误内容转化为越权执行或虚假业务结论的机会。模型仍可能误解、拒答或超时，因此自评不使用“零幻觉”“绝对安全”等不可证承诺。

多层防护与触发行为

风险	防护实现	系统应有的反应
编造收款人或账号	可信本人目录和资源标识校验	不能映射时追问或拒绝准备。
编造工具或危险参数	工具注册表、Schema和计划校验	拒绝未知工具、额外字段和不匹配版本。
要求忽略规则或扮演管理员	文本不可信，权限从会话和后端配置取得	聊天声明不增加权限，仍走原确认流程。
用旧确认执行新金额	绑定参数快照、任务版本、操作与期限	要求核对新草案并重新确认。
谎称付款已完成	页面根据实际工具及持久结果呈现	保存草案、处理中和成功分别显示。
模型要求验证码或秘密	验证码在业务表单手动输入；秘密不下发	使用说明要求不向聊天发送码或真实银行卡资料。

关键写操作由程序控制

模型不能替代付款、冻结或订阅变更的明确确认；模拟验证码须用户手动填写原验证表单。付款和卡片的验证码及授权不共用。最终事务再次核对卡锁、余额、确认、许可与原单，防止仅凭模型一段正确格式的输出执行资金写入。

输出与供应商边界

协议约束模型输出计划或澄清，不凭模型文字生成资金成功结论。必要上下文会发给指定模型供应商，评委应只输入虚构测试资料。系统未给出幻觉率、攻击防御成功率或模型性能领先的统计结论；现有测试不能穷尽所有提示注入变体。

交易一致性与运行安全

交易安全既要阻止不允许的动作，也要在超时、断网和重启后保留真实结果。前端显示失败不构成资金未执行的证明。

资金安全

金额按明确单位校验；创建草案、付款确认、后台委托、验证、许可与完成分阶段记录。最终事务重核归属、收款映射、余额和冻结状态。同号重投沿原结果恢复，不再次扣款。只有证据证明未进入资金受理的草案才可结束，真实资金未知结果不会因新任务或计时被清除。

会话和网页防护

银行交互采用 HTTPS、HttpOnly/Secure/SameSite 会话 Cookie、Origin 与 CSRF 校验，并对业务响应使用 no-store。前端提供 CSP 等安全策略，公开 Pages 使用静态内容和 meta CSP；meta 不等于提供所有 HTTP 响应头。模型凭据和数据库凭据通过受限服务端配置提供，公开资料不含登录口令。

审计与恢复

业务结果与 Outbox 同事务保存，发送器重投原事件并核严格 ACK。接收侧校验事件、去重、持久化并计算本地记录哈希；发送失败保持可恢复状态，不手填回执。接收器具有本地哈希链和本地签名检查点能力；此前部署逐项核对新增事件与 ACK；后续只读核查307条本地链有效，检查点及可信外锚点未验证，链上存证不列为通过项。

版本与变更控制

维护45已在指定独审后实际采用。一次组织者解冻保留原锁、原因、冻结记录和回执，只追加管理凭证、公共事件及必要版本变化；同版网页只读核对当前状态。原维护44余额调整凭证与旧账保持，不通过回盖旧库或删除流水退回。

本轮实际检查

45独审相关后端12/12、付款执行/恢复/报告前端61/61通过。隔离真实HTTP验证金额边界、Red缺验证/错码/错会话/混操作和真实122秒过期拒绝、原号受理重投、再次冻结及冻结后后台不扣款；生产一次解冻、重启持久查询与严格ACK已核。百万只验准备与提示；维护45生产未新付款或冻回。

累计暴露的威胁与控制

把连续转账都当成孤立小额，会低估当前已经受理的出账暴露。SafeFlow用可信使用额提升验证要求，同时明确这条规则的能力边界。

威胁与当前控制

威胁或误读	已实现控制	验证及限制
多次小额被孤立看待	本人使用额U加本笔C；>1000元Red	900+200说明机制；310+690/690.01已有证据
刷新 / 换聊天清零	从资金与原公共提交读取，不信页面计数	同一可信用户范围；非跨真实银行统计
午夜漏掉处理中	UTC+8统计，旧日仍PROCESSING继续计入	不自动释放跨日占用或UNKNOWN
旧确认遇到新使用额	摘要失效；执行取锁后重读并最终取较高要求	有相关并发隔离证据，非完整防拆分证明
重复信号或重复请求叠加	中央计算器按事件及规则去重	COMPUTE_AUDIT_ONLY，网站未绑定八类信号

门槛与真实付款安全关系

恰好1000元不因金额规则升Red，但不是免验证承诺；最终还取工具已有要求的较高者。当前后台付款仍需本笔确认、模拟码、独立委托、有效许可、归属、余额和未冻结等条件。强验证门槛不是硬限额，也不能为展示Red跳过其他拒绝。

没有借分数替代授权

八类软风险目录定义了权重、时间窗口及缺失策略，可信计数可扩展接入，但网站未绑定真实设备/频次数据。0分/LOW只是数值区间，未评估必须单列。 RiskTier软分区间不等同SecurityLevel验证级别，低软分不能消除硬拒绝。

验证不扩张为安全保证

没有独有/首创或完整反欺诈已完成主张；未证明任意并发、外部直写、多用户或跨入口均无法拆分绕过。公开材料只引用既有隔离边界，不为本次文档新增模型、付款或冻卡测试。

已知风险与自评结论

以下内容是比赛提交要求中的已知风险清单，说明当前可接受的演示边界及进一步应用的条件，不将模拟环境包装成生产银行服务。

已知风险清单

风险或限制	当前控制	适用条件
评委共用身份与持续状态	私下发口令，提示操作保留、不自动重置	无法据此区分每位评委；不得当作真实客户账户。
同设备显示模拟验证码	绑定操作且手动输入，与确认分开	用于流程演示，不等于短信或银行强认证。
冻结卡影响后续付款	最终事务仍拦截，不自动解冻	先查当前卡状态；先转账后冻结，网页无自助解冻，再付款联系组织者。
模型错误与外部依赖	来源约束、独立校验、澄清和原结果恢复	不能保证每次模型理解正确或供应商持续可用。
订阅服务外部效果	明确本地意图和模拟提醒状态	不构成真实商户退订或外部通知送达。
本地审计与可信外部证明	哈希、去重、严格回执和检查点	尚无本次通过的可信外锚点或链上存证证明。
公网演示运行期限	身份有界，私有运维入口与恢复记录	现有后台身份已受控延期至北京时间2026年11月29日零点，覆盖11月28日全天；会话、确认、验证、许可及单笔委托期限不随之延长。

验证边界

前端测试、事务与恢复测试、独审和线上限定核验分别提供证据。本自评未宣称完成第三方全面渗透、全部并发负载、全部灾难恢复、供应商内部安全或生产级多用户认证验证。历史局部通过不扩大为全项目安全放行。

结论与责任

在虚构资料、私下口令、逐笔明确确认和有界权限的前提下，现有系统可用于评委体验银行 Agent 的对话、安全执行及恢复方法。公开页面只展示必要信息；真实应用前，组织者和相应业务提供方仍须按真实身份、认证、通知、运行与存证条件分别验证。

后端评测与验证范围

历史后端评测49项中45通过，4项旧资金/冻结测试曾在目标断言前失败。维护45已修复该F7夹具，相关12/12独审通过；历史失败保留，其余六项改进未因本轮部署而关闭。

已知待改进项

事项	实际影响与边界
聊天容量	两类聊天各有全局256容量，完成或登出不回收；第257条新建可被拒绝。
审计异常队列	选中坏记录或持续拒收的前批可能阻塞后续投递；线上核查时无积压。
发送端可观测性	当前宿主未保留Rust标准错误输出，未取得无进展告警证明。
接收端恢复	已配置异常自动重启（on-failure，间隔5秒），尚未进行实际故障恢复演练。
备份与恢复	45及47采用前后银行库、审计库dump已核大小、SHA及TOC，私有角色SQL仅核大小和SHA；均未做隔离恢复演练，不能据此关闭恢复风险。
健康状态	银行含旧固定能力标记，审计健康检查仅证明进程存活。

大额与安全测试如何理解

原隔离证据保留：使用额310元时690.00为Yellow、690.01为Red；45新证据中使用额0时999.99/1000.00为Yellow、1000.01为Red，且网页提示、错码及期限分支得到覆盖。它们证明公共最低验证要求与相关守卫，不等于完整风险评估；risk_mode=NOT_EVALUATED、domain_policy_evaluated=false仍属实。

审计与未验边界

解冻管理事件按原event_id由sender投递，接收器持久化并严格匹配ACK，旧审计前缀保持。此前307条本地链核查是当时快照，不冒充现在总数。接收器对源digest检查64hex格式并保存回显，不重算源envelope摘要；本地fingerprint与recordHash另算。无可信外锚点或本次链上存证，不证明抗管理员整体重写；完整压力、真实多租户、模型注入全矩阵及当前备份恢复仍未验证。